

BEFORE Placeholder

AFTER

RBAC Role Model Template (Supplier SaaS)

Document classification: Internal

Template owner: Security Engineering/Architecture

Version: 0.1

Supplier: _____ Service/Product: _____ Tier: ☐ Critical ☐

Important ☐ Low SSO method: ☐ SAML ☐ OIDC ☐ Not supported (exception required)

Provisioning: ☐ SCIM ☐ Manual ☐ Other: _____ Date created:

_____ Owner (role title): _____

1) Purpose and scope

What is this role model protecting/enabling (1–2 sentences)?

Environments in scope: ☐ Production ☐ Non-production ☐ Both

2) Role design principles (tick)

☐ Least privilege by default

☐ Named admins only (no shared admin accounts)

☐ Separate admin vs day-to-day roles

☐ Read-only roles available and used

☐ External sharing restricted (if applicable)

☐ Break-glass is separate and controlled (if applicable)

3) Role catalogue

Define the minimum set of roles you will use. Add rows as needed.

Role name (in supplier)	Intended users (job function)	Permissions summary (plain English)	High-risk actions allowed? (Y/N)	Approval needed to assign? (Y/N)	Notes
Viewer / Read-only			N	N	
Standard User			N	N	
Power User			Y/N	Y	
Admin (Scoped)			Y	Y	
Tenant/Global Admin			Y	Y	Minimise count
Security Admin (if available)			Y	Y	
Billing/Admin (if available)			Y/N	Y/N	

High-risk actions examples (for reference): user/role management, policy/config changes, API scope changes, exporting sensitive data, disabling MFA/logging.

4) Group-to-role mapping (recommended)

Map roles to identity provider groups for consistent access control.

IdP group name	Supplier role(s) assigned	Membership rules (who qualifies)	Owner (role title)	Recertification cadence

Rules:

- Admin groups MUST have restricted membership and approval to join.

- Prefer job-function-based groups rather than individuals.

5) Assignment and approvals

Role assignment model: ☐ Automatic via group membership

☐ Manual assignment in supplier console (minimise; document why)

Approvals required:

- For Admin/Tenant Admin roles: Approver (role title) _____
- For Power User roles: Approver (role title) _____

Access review cadence:

- Tier Critical: ☐ Quarterly ☐ Semi-annual ☐ Annual (justify): _____
- Tier Important: ☐ Semi-annual ☐ Annual
- Tier Low: ☐ Annual ☐ Trigger-based only

6) Break-glass / emergency access (if applicable)

Is break-glass required by supplier or operational need? ☐ Yes ☐ No

If Yes: Break-glass account(s) name(s): _____ Storage
method (vault/secure store): _____ Holders (role titles):
_____ Use conditions (when permitted):

Post-use review required by (role title): _____ Logging/alerting
enabled for use: ☐ Yes ☐ No Notes: _____

7) Auditability and monitoring

Audit log sources available (tick): ☐ Admin actions ☐ Auth events ☐ Role changes ☐ Data exports
☐ API activity

Log retrieval method: ☐ Supplier portal export ☐ API ☐ Forwarding/connector ☐ Other: _____

Alerting required (Critical recommended): ☐ New admin assigned ☐ MFA disabled / auth policy changed ☐ Large data export ☐ Unusual login location/IP (if available) ☐ Failed login burst / brute force indicators

8) Exceptions / deviations

List any deviations from least privilege or SSO requirements (with rationale):

•

Exception required? ☐ Yes ☐ No Exception ID (if yes): _____

9) Validation checklist

- ☐ Roles reviewed for least privilege
- ☐ Admin roles restricted to named users
- ☐ Group mapping implemented and tested
- ☐ Access assignment approvals documented
- ☐ Access review cadence scheduled
- ☐ Audit logging enabled and validated

Sign-off (generic role titles) Security Engineering/Architecture: _____ Date: _____

IT/Platform Owner: _____ Date: _____ Business Service Owner:

_____ Date: _____ DPO/Privacy Officer (if personal data in scope): ____ Date: _____